Trusted Delegated Payments for Autonomous Agents

I. Scope

An AI agent sits inside a device. It could be a smart home appliance or a vehicle charger or a diagnostic instrument. The agent prepares the cart as per the initially given instruction of the user. My work starts when the basket is finished and the agent asks to pay. It ends when the money has moved and the evidence is recorded. Product discovery and price comparison and supplier choice all happen before that. They are out of scope.

I restrict the problem to repetitive purchases. The same consumable is reordered again and again across different merchants. This is what makes advance authorisation meaningful. The owner cannot approve each purchase but they can approve the pattern.

II. Payments background

A. UPI

UPI is India's real time retail payment system. It is operated by NPCI which is a not for profit consortium of banks. A user is addressed by a virtual payment address like `name@bank`. That address resolves to a bank account. A payment is a message routed through a central switch. The switch debits one bank and credits another. It settles in seconds.

Two properties matter here. UPI charges the merchant no fee on most transactions, so unlike cards there is no fee stream funding a dispute and chargeback apparatus, and none was ever built. Authentication is a four or six digit UPI PIN entered on a device bound to the user, so the base security model assumes a human is present.

B. Mandates

A mandate is standing authorisation to debit an account without fresh authentication each time. Three kinds matter, and the third one is recent enough that most writing on this topic predates it.

UPI Autopay is a recurring mandate. It is bound to one payee and one amount ceiling and a schedule. It was built for subscriptions. The payee is fixed when the mandate is created.

UPI Reserve Pay is formally called Single Block Multiple Debits. It blocks funds inside the user's own account. A merchant then debits against that blocked pool repeatedly until it is empty or expires. The ceiling is Rs. 10,000 and validity is 90 days. A customer may hold one active block per merchant, so several blocks may run at once against different merchants. Source is NPCI Operating Circular 228 of October 2025.

UPI on IoT is the one that matters most for this project. NPCI Operating Circular 201-B of 8 October 2025 brought devices and software into the UPI Circle delegation framework, extended on 6 January 2026. The owner links a device from their own UPI app, sets a limit, and authenticates once with a UPI PIN or biometric. That device may then pay up to Rs. 5,000 per transaction and Rs. 15,000 per month, capped at Rs. 2,000 in the first 24 hours after linking, with at most five devices per owner, restricted to domestic merchant payments.

C. Where the hole is

Authentication happens once, when the mandate is created or the device is linked. Every debit after that is unauthenticated by the human. The rail carries no field saying who or what started a debit.

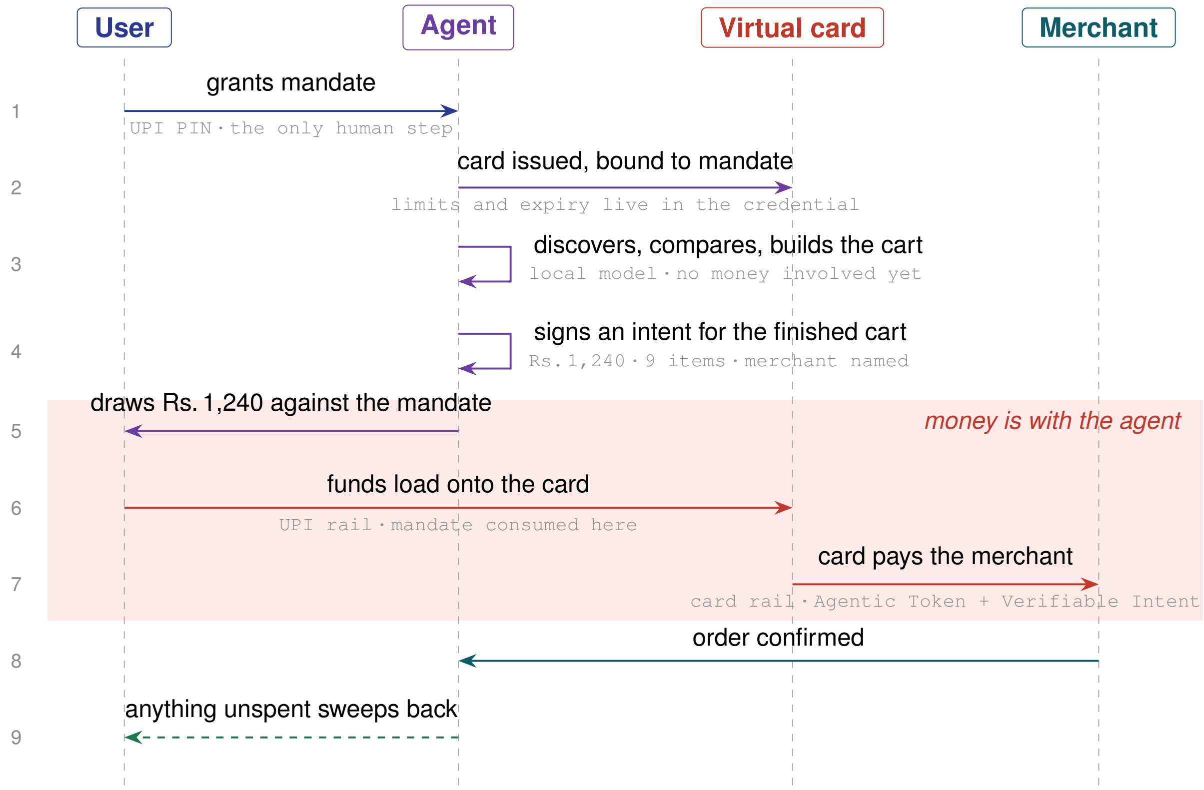

Fig. 1. The flow this project is about. Step 1 is the only moment a human is present. Step 3 is out of scope: discovery and comparison happen before the cart is finished, and my work begins at step 4. The shaded band is the window in which the money has left the owner's account and has not yet reached the merchant.

D. Cards and why they are different

Card networks spent two decades building infrastructure that assumes an adversary. UPI never needed that. Cards have tokenisation and network side authorisation policy and a formal dispute process with defined liability shifts and a 120 day chargeback window.

Tokenisation replaces a card number with a network issued token scoped to a context. This is what Apple Pay does. The token is a reference and not a bearer instrument. It holds no value. It de-tokenises inside the network back to the real account.

E. The asymmetry that shapes everything

UPI is cheap and everywhere in India. Since Circular 201-B it can register a device or a software profile as a delegate, but what it enforces is a limit. It carries no agent identifier on the transaction, no merchant scope, and no notion of what was bought. Cards are expensive but they carry an agent identifier, enforce merchant and category scope at the network, and have a dispute process with defined liability.

- Payment Gateway, Payment Processor and Payment Security Explained
- How UPI Works: Real-Time Payments in India | PayPal | Zelle

So my system spans both rails. The owner picks which one funds a given agent. Figure 1 is the whole flow on one page. It is worth reading before the protocol section because everything after it refers back to a step number.

III. The protocol landscape

A. AP2 from Google, September 2025

AP2 defines three signed artifacts as W3C Verifiable Credentials. An Intent Mandate says what the user asked for. A Cart Mandate says what the agent selected. A Payment Mandate authorises the movement. Each artifact is non repudiable.

B. Mastercard Agent Pay and Verifiable Intent

Agentic Tokens extend card tokenisation. They add an agent identifier and a scope object holding spend caps and merchant categories and expiry. The network validates that scope at every single authorisation.

Verifiable Intent was open sourced in March 2026. It is a credential that travels with the authorisation and cryptographically links the transaction to the human mandate behind it.

Mastercard calls their framing Know Your Agent. It asks three questions: Is the controlling human verified. Are the agent's keys in TEE hardware. Is the delegation scope well defined.

C. P3P from Pine Labs, June 2026

P3P is the closest system to my project and it is live in production. It runs agentic payments over UPI Reserve Pay and One Time Mandate using HTTP 402. An identity and delegation layer called Grantex supplies agent identity and spend limits and an audit trail.

It is single merchant. Reserve Pay blocks funds against one named merchant, so anything built on Reserve Pay inherits that scope.

The live deployment is Gullak, a digital gold savings app. The owner sets a rule such as buy Rs. 500 of gold if the price falls below Rs. 16,000 per gram, approves one mandate, and the agent executes when the condition holds. Vijay Sales is running a proof of concept of the same shape, buying one named product when it reaches a target price.

Those two cases have one thing in common. One merchant, one item, and a condition the rail can evaluate as a number. There is no basket, so there is nothing to substitute and nothing to compare against.

Open question. Pine Labs' public documentation still does not say whether a payment is bound to an approved order. It states that payment tokens are tied to a specific resource and amount and expiry, which is the HTTP 402 shape rather than a basket.

D. x402 and MPP

Both revive HTTP status code 402. x402 from Coinbase settles USDC on chain using EIP-3009 gasless authorisations verified by a facilitator. MPP from Stripe and Tempo is a general HTTP authentication scheme on an IETF track with payment methods defined as separate specifications.

Both solve the problem of paying for an HTTP resource. There the thing purchased is the request itself. Neither needs an order record because there is no basket.

IV. Proposed authorisation and evidence layer

- **Agent Registration:** A cryptographic identity linking each agent to a verified owner and host device. Multiple agents can run on one device, and revoking one agent does not affect the others.
- **Authority Creation:** The owner defines a per-purchase ceiling, period budget, category scope, and expiry. This authority is recorded as a ReservePay block on UPI or an Agentic Token on cards after one-time authentication.
- **The Order Check:** Before settlement, arithmetic checks should verify that the payment matches the original order and that the order remains within the authority granted by the owner.
- **The Cross-Rail Receipt:** A single signed record binds the mandate, order, and both payment legs. It provides cryptographic evidence of what was authorised and what actually happened, while ensuring that the amounts agree across all four elements.
- **Owner Control Interface:** A mobile interface allows the owner to create, edit, revoke, and monitor mandates, while also providing a unified view of purchase history across both payment rails.
- **Reconciliation:** Every payment ends in one of three states: *failed*, *succeeded*, or *unknown*. The unknown state is critical because payment networks can lose certainty about the final outcome. Also, how a dispute will be settled when the payment fails.

One major problem: prompt injection is an attack where someone puts malicious instructions into content that an AI agent reads, which can manipulate the agent to do something.

V. Machine payment use cases

The use cases depend on different maturity levels.

A. Transacting today: beachhead use cases

- **EV Charging:** Charging stations already process machine-triggered payments. The amount can depend on the station, charging duration, time, and energy consumed, making this a natural use case for autonomous payments.
- **Battery Swapping:** Two- and three-wheeler networks generate frequent, small-value transactions. A vehicle or its associated agent can identify the need for a battery swap and initiate payment automatically.
- **Water Tanker Delivery:** Businesses and facilities may require recurring water deliveries from multiple suppliers. Prices can change frequently and the owner may not be physically present, making autonomous ordering and payment valuable.
- **Diagnostic Analysers:** Laboratory analysers consume reagents and consumables. Machine telemetry can identify replenishment requirements and initiate orders which can reduce the risk of laboratory downtime.

Why these are the beachhead: The machines are already deployed, the transaction is already necessary, and the payment can be tied to a well-defined machine event.

B. Deployed, but not yet automated: near-term

The physical infrastructure already exists but the missing capability is primarily autonomous decision-making and payment authorisation.

- **Water Purifiers:** Monitor cartridge usage and automatically order replacements when the remaining capacity falls below a threshold, rather than relying on calendar-based replacement.
- **Vending Machines and Micro-Markets:** Machines already monitor inventory and can determine when products need replenishment. Autonomous payment allows the machine to reorder stock without manual intervention.

- **Fleet Fuel and Tolls:** Vehicles can transact for fuel, tolls, and related services under a fleet-level mandate. Individual transactions remain within limits defined by the fleet owner.
- **Industrial Consumables:** Industrial equipment can use telemetry to identify low levels of tools, spare parts, or consumables and automatically initiate replenishment.
- **LPG and Generator Fuel:** Fuel levels can be monitored continuously, allowing the machine or associated agent to book replenishment before exhaustion and avoid operational downtime.

C. *Consumer and connected-home agents: expansion*

- **Amazon Echo Dot / Alexa:** A voice-enabled agent can manage recurring household purchases. For example, the owner can authorise household-supply spending and allow Alexa to reorder detergent, groceries, or other frequently purchased items when required.
- **Google Home / Google Nest:** Similar agentic behaviour can be applied to household replenishment and services. The device can act on the owner's standing authority rather than requiring explicit approval for every individual purchase.
- **Smart Refrigerators:** The refrigerator can monitor food inventory and trigger grocery orders when items fall below predefined thresholds.

VI. Useful readings

1) **NPCI UPI Delegation Framework:**
   UPI Circle.
   https://www.npci.org.in/product/upi-circle
2) **UPI Reserve Pay:**
   https://razorpay.com/blog/upi-reserve-pay/
   https://www.pinelabs.com/docs/online-payments/upi-reserve-pay
3) **Agent Payments Protocol (AP2):**
   Google, "Agent Payments Protocol." AP2 provides a protocol-level framework for agentic payments and uses Verifiable Credentials as part of its artifact model.
   https://ap2-protocol.org
4) **Agentic Payments and Agentic Tokens:**
   Mastercard, "Agent Pay and the Agentic Token Framework." The Know Your Agent (KYA) questions discussed in Section III-B are derived from this work.
   https://www.mastercard.com/us/en/business/artificial-intelligence/mastercard-agent-pay.html
5) **Agent to Agent Protocol:**
   https://a2a-protocol.org/latest/
6) **P3P – Pine Labs Payment Protocol:**
   Pine Labs, "P3P Documentation." P3P provides a practical framework for delegated agentic payments and mandates.
   https://www.pinelabs.com/docs/online-payments/ai/p3p
7) **Verifiable Credentials:**
   W3C, "Verifiable Credentials Data Model 2.0." This specifies the credential format used by AP2.
   https://www.w3.org/TR/vc-data-model-2.0/
8) **Ed25519 and Digital Signatures:**
   Eiken, "Code Spotlight: The Reference Implementation of Ed25519 (Part 1)," 2020. This provides an implementation-oriented explanation of Ed25519 digital signatures.
   https://www.eiken.dev/blog/2020/11/code-spotlight-the-reference-implementation-of-ed25519-part-1/
9) **Verifiable Intent and Agentic Payments:**
   Mastercard, "How Verifiable Intent Builds Trust in Agentic AI Commerce," 2026.
   https://www.mastercard.com/in/en/news-and-trends/stories/2026/verifiable-intent.html

10) **Know Your Agent:**
How KYA Secures Autonomous AI.
https://www.1kosmos.com/resources/blog/know-your-agent-kya-securing-autonomous-ai

11) **Agentic Commerce and Know Your Agent:**
LinkedIn, "As AI Agents Begin to Participate in Commerce," 2026.
https://www.linkedin.com/posts/as-ai-agents-begin-to-participate-in-commerce-share-7472502038367686656-HGI

12) **Know Your Agent (KYA):**
Jelena Hoffart, "Everything You Need to Know About Know Your Agent (KYA)," Medium.
https://medium.com/@jelenahoffart/everything-you-need-to-know-about-know-your-agent-kya-bcaa45117522

13) **Adversarial Machine Learning:**
NIST, "Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations," NIST AI 100-2 E2025. This provides the relevant taxonomy for threats such as prompt injection and other adversarial attacks against AI systems.
https://csrc.nist.gov/pubs/ai/100/2/e2025/final

14) **Trusted Execution Environment Provisioning (TEEP):**
IETF, "RFC 9397: Trusted Execution Environment Provisioning (TEEP) Architecture."
https://datatracker.ietf.org/doc/rfc9397/

15) **Remote Attestation (RATS):**
Gufran Mirza, "RATS: Remote Attestation Architecture." This provides an accessible introduction to remote attestation and its role in establishing trust in execution environments.
https://gufranmirza.com/blogs/rats-remote-attestation-architecture

16) **Remote Attestation for Confidential Computing:**
Literature on Intel TDX and AMD SEV-SNP. These systems provide the technical basis for the trusted-execution and attestation properties referred to in this brief.

17) **Unverified Instruction Origin After Mandate Creation:**
arXiv, "arXiv:2604.15367." This work establishes that the problem of unverified instruction origin after mandate creation has already been identified. Consequently, the contribution should focus on a concrete enforcement mechanism rather than merely restating the observation.
https://arxiv.org/abs/2604.15367